

of the document in question.

2. Considerations of the Authority

The Authority, having examined the complaint and the documentation provided, notes that the complainant has exercised her right of access to personal data as per Article 15 of the Regulation. The Authority acknowledges the response provided by the Hospital, which asserts that the complainant was given a complete copy of her medical records, including consent forms for the processing of personal and sensitive data.

3. Findings

The Authority finds that the Hospital has complied with the request for access to personal data by providing the complainant with a copy of her medical records. However, the inclusion of another individual's medical report in the complainant's records raises concerns regarding the accuracy and integrity of the data processed by the Hospital.

4. Conclusion

In light of the findings, the Authority emphasizes the importance of ensuring that personal data is processed accurately and that appropriate measures are taken to prevent the mixing of personal data belonging to different individuals. The Hospital is reminded of its obligations under the Regulation to implement adequate technical and organizational measures to safeguard personal data.

5. Order

The Authority orders the Hospital to:

- Review its data management practices to prevent future occurrences of data mixing.
- Provide training to its staff on data protection and the importance of maintaining the confidentiality and integrity of personal data.

This decision is made in accordance with the powers conferred upon the Authority by the applicable legislation and is subject to appeal in accordance with the provisions of the law.

Done in Rome, on December 7, 2023.

The President,

Prof. Pasquale Stazione

of the report concerning the mentioned patient. In light of these new elements that emerged during the investigation, the Office, with note dated XX (prot. n. XX), requested from the Hospital Company, pursuant to Article 157 of the Code, information regarding the reported event.

In this regard, with note dated XX (prot. n. XX), the data controller, responding to the Authority, stated, among other things, that:

- "(...) Within the medical record of Ms. XX, the presence of health documentation of another patient (Ms. XX) was found. The medical record of Ms. XX concerns her hospitalization which began on XX and ended with discharge on XX (...). The medical report of another patient, included in Ms. XX's medical record, pertains to the cardiotocographic tracing of Ms. XX, performed at the UOC of Gynecology and Obstetrics on XX at XX hours, as digitally indicated on the report sheet (...)."
- "(...) with note n. XX dated XX (Attachment A), the Health Directorate of the A.O.U. mandated the U.O.C. Staff to initiate a specific audit to analyze the critical issues and identify corrective actions aimed at (...) improving the management process of the medical record in the Gynecology and Obstetrics department and improving the management process of the medical record at the Medical Records Office, with particular reference to the phase of 'preparation of the copy for the entitled party';
- "(...) Considering the chronological simultaneity of the dates of Ms. XX's hospitalization and the date of execution of the report of Ms. XX (the date of execution of the report falls within the period of Ms. XX's hospitalization), the inclusion of the cardiotocographic report within Ms. XX's medical record occurred on XX, at the Gynecology and Obstetrics department, during the period of Ms. XX's hospitalization."

Among the "corrective measures adopted to improve the management process of health documentation in the UOC of Gynecology and Obstetrics," the data controller indicated having

undertaken some administrative actions, attaching the relevant documentation in support of the statements made. In particular, “with the Resolution of the Extraordinary Commissioner no. XX dated XX, the revision of Procedure XX (...) on the management, compilation, and release of health documentation was adopted; (...) rigid folders with elastic bands and binders were delivered to the U.O.C. Gynecology and Obstetrics to ensure the proper storage of reports and health documentation in order to prevent the exchange of sheets or their insertion into the records of other patients; (...) the A.O.U. signed document Prot. XX dated XX (...) on the planning of training interventions also in the field of data protection.”

Among the “(...) corrective measures to be adopted to improve the management process of health documentation in the UOC of Gynecology and Obstetrics,” the data controller stated, “the purchase of tablets has been planned (...) (for) the completion of the process of computerization of the medical record in order to dematerialize all health documentation and eliminate the use of paper reports.”

Finally, the Hospital Company declared that it had adopted “corrective measures to improve the management process of health documentation at the medical records office,” such as:

- “(...) the immediate identification of the figure of the Responsible person with the role of coordinating the staff (...) operating within the Medical Records Office and systematically interfacing with the Health Directorate Representative; (...) a formal request for the appointment of a coordinator (...) to ensure greater control in the phase of delivery of documentation; (the introduction of) (...) the figure of the ‘Health Directorate Representative for the Release of Health Documentation Office’ who will oversee the application of the procedure itself and the activities to be carried out in the work processes aimed at releasing health documentation to entitled parties, also signing an internal module for the certification of the health documentation to be released. (...) (planning for the) purchase or in-house development of an application for the secure management of the request and release process of health documentation in order to ensure traceability and quality in the collection of information.”

Based on the documentation on file and the evaluations made, the Office, with note dated XX (prot. n. XX), addressed to the complainant, deemed it appropriate to close the investigative procedure regarding some of the alleged profiles of violation raised in the complaint; this, with partial archiving of the same complaint - communicated to the Hospital Company with note dated XX (prot. n. XX) – and, specifically, with regard to:

- a) the alleged loss of data by the data controller for having the interested party received a document “(...) protocol XX dated XX – (which) states: ‘the medical record is a true copy of the original present in the company’s IT system but lacking the paper component still not retrievable at the operational unit’;
- b) the alleged failure to sign “(...) consents/information for data processing activities.”

The above, due to the fact that the Office did not find grounds for the adoption of a measure by the Board in light of what was stated by the data controller (see note prot. n. XX dated XX in which the Hospital Company states that: “on XX the Company delivered to the interested party...

a cartella clinica ha subito un notevole incremento del carico di lavoro, il che ha portato a disguidi e errori nella gestione dei documenti.

3. Conclusioni

Alla luce di quanto sopra esposto, si evidenzia che l’Azienda Ospedaliera ha violato le disposizioni di cui agli articoli 12 e 15 del Regolamento, nonché i principi di protezione dei dati personali previsti dagli articoli 5 e 9 del medesimo Regolamento. Inoltre, si rileva una carenza nell’adozione di misure di sicurezza adeguate, come stabilito dall’articolo 32 del Regolamento, che ha contribuito alla diffusione non autorizzata di dati personali sensibili.

4. Provvedimenti

Si invita pertanto l’Azienda Ospedaliera a:

- adottare misure correttive immediate per garantire la conformità alle normative sulla protezione dei dati personali;
- fornire un piano dettagliato delle azioni intraprese per prevenire il ripetersi di simili incidenti in futuro;
- comunicare tempestivamente al Garante eventuali ulteriori sviluppi o misure adottate in merito alla

questione.

5. Termine per la risposta

L'Azienda Ospedaliera è tenuta a fornire una risposta scritta entro 30 giorni dalla ricezione della presente comunicazione, indicando le misure adottate e le eventuali giustificazioni in merito alle violazioni riscontrate. In mancanza di una risposta adeguata, si procederà con ulteriori azioni ai sensi della normativa vigente.

Data: XX

Firma: [Nome e Cognome]

[Posizione]

[Ufficio]

the archive of medical records at the U.O.C. of Gynecology and Obstetrics had the right to carry out activities in smart working mode. Such circumstances had an adverse impact - especially during the initial emergency phase - also on the management aspect of the sequential activities related to medical records. (...) the conduct carried out was negligent”;

“during the period in question - from December 2020 (date of hospitalization of) and for the following years - the emergency state due to the Covid-19 pandemic severely challenged the Company, as indeed all healthcare facilities, both at the assistance and management level and in the planning of the staff in service. Moreover, the A.O.U. “G. Martino” was a Covid Hospital and this, consequently, led to a general organizational revision also for the management of human resources from which some critical issues regarding the processes for the release of health documentation could arise”;

“To address such critical issues and to compensate for the difficulties recorded in the archiving and retrieval of the clinical documentation accumulated during the period in question in the aforementioned operational unit, with note Prot. XX of XX, the Company Management identified and assigned a unit of personnel with experience acquired during their professional activity to carry out such tasks (...)”;

“(...) it is reiterated (...) that it was a human error certainly not intentional and that the violation involved only one patient”;

“(...) organizational measures have been adopted and training initiatives have been planned to raise staff awareness of compliance with data protection regulations.”

In light of the above statements, the data controller has requested the Authority to proceed with the archiving of the present procedure or, in the denied case of the adoption of corrective and sanctioning measures, the recognition of mitigating circumstances that will allow the application of sanctions to the minimum possible extent.

3. Outcome of the investigative activity

Taking note of what has been represented and documented during the procedure by the Hospital Company, first with the responses to the aforementioned information requests and, subsequently, in the defensive memorandum, the following observations are made.

3.1 Data subject to processing

Personal data is understood as “any information relating to an identified or identifiable natural person (‘data subject’)” and “data concerning health” refers to “personal data related to the physical or mental health of a natural person, including the provision of health care, which reveals information about their health status” (art. 4, paragraph 1, nos. 1 and 15 of the Regulation). The latter data deserves greater protection since the context of their processing could create significant risks to fundamental rights and freedoms (Recital no. 51). The data processed in the case in question, pertaining to health services, are classified as health-related data.

3.2 Failure to respond to the request for the exercise of rights (art. 12 in relation to art. 15 of the Regulation).

Regarding information, communications, and transparent modalities for the exercise of the rights of the data subject, art. 12, par. 3, of the Regulation establishes that the data controller must respond to the

request of the data subject, made pursuant to arts. 15 to 22 of the Regulation, without undue delay and, in any case, no later than one month from receipt of the request. This term may be extended by two months, if necessary, taking into account the complexity and number of requests, provided that the data subject is informed of such extension and the reasons for the delay within one month of receiving the request. If the data controller does not comply with the request of the data subject, they must, in any case, inform the data subject without delay and, at the latest, within one month from receipt of the request, of the reasons for non-compliance and the possibility of lodging a complaint with a supervisory authority and of seeking judicial remedy (cons. 59 and art. 12, par. 4, of the Regulation).

In relation to the request for the exercise of rights under art. 15 of the Regulation made by the data subject on XX, the data controller did not provide an adequate response within the timeframes indicated by art. 12 of the Regulation. The response - deemed adequate by the complainant (cf. complainant's note to the Authority of XX) - was provided by the data controller on XX. This late compliance occurred following an exchange of preliminary emails between the data controller and the data subject and subsequently to an initial partial response, provided, however, beyond the deadlines set by art. 12 of the Regulation, on XX, the date on which "the complainant's husband, appointed by her, was received in the offices of the company's strategic management to receive the necessary apologies and the digitized copy of the documents" (cf. defensive memorandum of XX). This should be taken into account when assessing the severity of the data controller's conduct, but it is also relevant concerning the duration of the violation, as the data controller, in these exchanges with the complainant (cf. emails attached to the complaint between the Hospital Company and the complainant) never highlighted reasons for complexity in fulfilling the request for access to the data, so that there were no reasons that would have made a possible two-month extension - in the sense indicated by art. 12, par. 3) of the Regulation - for responding to the request justifiable.

within one month, or by the XX. The response provided on XX resulted in a delay of 232 days compared to the deadline for the response to the interested party set by the cited regulation. The data controller provided an appropriate response to the interested party on a later date (XX) following the complaint submitted by the latter to the Authority (XX), but prior to becoming aware of the submission of such complaint, having learned of it through the request for information made by the Authority itself (XX). The Hospital Company, as measures aimed at preventing similar conduct, has planned training initiatives and given "(...) dissemination for broader sharing with all company personnel regarding the Regulation for the exercise of the rights of the interested parties (...)" (see defensive memorandum of XX).

3.3 Unlawful communication of health-related data in violation of the principle of integrity and security of data and the security obligations related to data processing as provided by the Regulation (Articles 5, letter f), 32, and 9 of the Regulation)

The Regulation stipulates that the data controller is required to comply with the principles regarding data protection, among which is the principle of "integrity and confidentiality," according to which personal data must be "processed in a manner that ensures adequate security (...), including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical and organizational measures" (Article 5, paragraph 1, letter f) of the Regulation); moreover, the data controller must implement "appropriate technical and organizational measures to ensure a level of security appropriate to the risk," taking into account, among other things, "the nature, scope, context, and purposes of the processing, as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons" (Article 32 of the Regulation).

In the healthcare sector, the regulations regarding the protection of personal data stipulate that information about health status can only be communicated to the interested party and can be communicated to third parties based on an appropriate legal basis or at the request of the interested party, with prior written delegation from the latter (Article 9 of the Regulation and Article 84 of the Code in conjunction with Article 22, paragraph 11, Legislative Decree No. 101 of August 10, 2018).

What was delivered on XX by the Hospital Company to the interested party (as a response to the request made in the exercise of the right under Article 15 of the Regulation - namely a copy of the data

pertaining to their medical record related to the hospitalization “(...) which began on XX and concluded with the discharge date of XX”) - containing the medical report of another patient, resulted in an unlawful communication of health-related data as there was no legal basis that would render the knowledge of such report by the interested party lawful.

It should be noted that the incident that occurred during the claimant's hospitalization at the Hospital Company (XX) coincides with the emergency period for the Covid-19 pandemic, regarding which the Company claimed that “it severely strained the Company, as indeed all healthcare facilities, both at the assistance level and in the management and programming of the staff in service. Moreover, the A.O.U. “G. Martino” was a Covid Hospital and this, consequently, led to a general organizational revision even for the management of human resources from which some critical issues for the processes regarding the release of health documentation could have arisen.” Generally, the insufficiency of human resources compared to the tasks related to the activities of the data controller does not constitute a justification aimed at mitigating the responsibility of the data controller (in this sense, see the document “Guidelines on the application and setting of administrative fines for the purposes of Regulation 2016/679,” WP 253 adopted on October 3, 2017, regarding the application of administrative sanctions); however, in cases like those caused by the recent Covid-19 pandemic, in which there has been a shortage of personnel in Companies and healthcare facilities throughout the national territory for unpredictable and unpreventable reasons, such organizational criticality must be taken into account (in this sense, see also the EDPB document “Guidelines 04/2022 on the calculation of administrative fines under the GDPR” Version 2.1 adopted on May 24, 2023, paragraph 5.9, point 111).

It is also considered that the Hospital Company has adopted corrective measures aimed at “improving the management process of the medical record in the Gynecology and Obstetrics department and (...) at the Medical Records Office with particular reference to the phase of ‘preparation of the copy for the entitled party,’ in addition to planning other measures to be adopted, including training interventions for the staff.

4. Conclusions

In light of the evaluations mentioned above, taking into account the statements made by the data controller during the investigation and considering that, unless the act constitutes a more serious crime, anyone who, in a proceeding before the Guarantor, falsely declares or certifies news or circumstances or produces false acts or documents is liable under Article 168 of the Code “Falsehood in declarations to the Guarantor and interruption of the execution of the tasks or exercise of the powers of the Guarantor” - the elements provided by the data controller in the defensive memoranda, although deserving of consideration, do not allow for overcoming the objections notified by the Office with the initiation of the procedure, as none of the cases provided for by Article 11 of the Garante Regulation No. 1/2019 apply. Therefore, in relation to the matter in question raised by the complainant, the preliminary assessments of the Office are confirmed, and the illegality of the processing of personal data carried out by the Hospital Company is noted, as it has been established, for the reasons mentioned above, that the latter, as the data controller:

- a) did not provide, within the terms set out in Article 12 of the Regulation, an adequate response to the request for the exercise of rights made, pursuant to Article 15 of the Regulation, by the data subject on XX, responding to this request on XX, that is, after 232 days from the deadline by which it should have responded to the data subject;
- b) communicated health-related data without a legal basis, providing the complainant - along with the copy of the health data requested by her - also with data related to a report concerning another patient of the Hospital without authorization from the latter.

Such conduct is therefore found to be in violation of Article 12, in relation to Article 15 of the Regulation, as well as in violation of the principles set out in Articles 5 par. 1, lett. f) and 9 and the security obligations set out in Article 32 of the same Regulation.

In this context, considering that the conduct of the data controller has exhausted its effects as the Hospital Company has provided - with reference to the request for access to the data in question - a response to the data subject and, with reference to the unlawful communication of health data, has proceeded to destroy the copy of the report of another patient mistakenly delivered to the complainant,

as well as to adopt technical and organizational measures deemed necessary to prevent future similar omissions and occurrences like those in question and, in any case, to minimize human error, the conditions for the adoption of measures, of a prescriptive or prohibitory nature, pursuant to Article 58, par. 2, of the Regulation, do not apply.

5. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, par. 2, lett. i and 83 of the Regulation; Article 166, paragraph 7, of the Code).

The violation of Articles 5, par. 1, lett. f), 9, 12, in relation to 15, and 32 of the Regulation, caused by the conduct carried out by the University Hospital Company "G. Martino" of Messina, is subject to the application of the administrative pecuniary sanction pursuant to Article 83, par. 4, lett. a) and par. 5, lett. a) of the Regulation and Article 166, paragraphs 1 and 2, of the Code.

The Garante, pursuant to Articles 58, par. 2, lett. i) and 83 of the Regulation, as well as Article 166 of the Code, has the power to "impose an administrative pecuniary sanction pursuant to Article 83, in addition to [other] corrective measures referred to in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case" and, in this context, "the Board [of the Garante] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Garante's website pursuant to Article 166, paragraph 7, of the Code" (Article 16, paragraph 1, of the Garante Regulation No. 1/2019). In this case, in relation to the processing operations carried out by the data controller, considering that they were related treatments, it is deemed necessary to apply paragraph 3 of Article 83 of the Regulation where it provides that "If, in relation to the same processing or related treatments, a data controller [...] violates, with intent or negligence, various provisions of this regulation, the total amount of the administrative pecuniary sanction does not exceed the amount specified for the most serious violation, the total amount of the sanction is calculated so as not to exceed the maximum penalty provided for by the same Article 83, par. 5" (see also the EDPB document "Guidelines 04/2022 on the calculation of administrative fines under the GDPR" Version 2.1 adopted on May 24, 2023).

The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into account the principles of effectiveness, proportionality, and deterrence, as indicated in Article 83, par. 1, of the Regulation.

Regarding the assessment of the severity of the violation (Article 83, par. 2, lett. a), b) and g) of the Regulation), concerning the failure to respond to the request made in exercising the right referred to in Article 15 of the Regulation as per lett. a) of the previous paragraph 4 "Conclusions", it is deemed that this was an isolated case and without intent, considering that a first partial response was provided to the data subject on XX and that apologies were expressed to the data subject; the response, provided on XX, after 232 days from the deadline set by Article 12 of the Regulation, was also provided before the Authority acted against the data controller who became aware of the complaint made by the data subject after the response was provided; regarding the unlawful communication of data referred to in lett. b) of the previous paragraph, it is noted that this concerned health-related data and involved 1 data subject; based on what was stated by the data controller, no intentional behavior emerges regarding the incident as it was a human error.

In relation to the assessment of aggravating and mitigating circumstances, it is taken into account that:

- no measures have previously been adopted against the Hospital Company regarding relevant violations (art. 83, par. 2, lett. e) of the Regulation);
- the data controller has specified that the historical context at the time of the occurrence related to the violation referred to in lett. b) of the previous paragraph n. 4 "Conclusions" was characterized by organizational difficulties caused by the emergency situation due to the Covid-19 pandemic, concerning the "(...) processes for the issuance of health documentation" (art. 83, par. 2, lett. k) of the Regulation).

In light of the aforementioned elements, assessed as a whole, it is deemed appropriate to determine the amount of the administrative fine provided for by art. 83, par. 4, lett. a) and par. 5, lett. a) of the Regulation, in the amount of €8,000.00 (eight thousand) for the violation of arts. 5, par. 1, lett. f), 9, 12 in relation to arts. 15 and 32 of the Regulation, as an administrative pecuniary sanction deemed,

pursuant to art. 83, par. 1, of the Regulation, effective, proportionate, and dissuasive.

It is also considered that the accessory sanction of publication on the website of the Authority of this provision should be applied, as provided for by art. 166, paragraph 7 of the Code and art. 16 of the Regulation of the Authority n. 1/2019, in consideration of the nature of the data processed.

Finally, it is noted that the conditions referred to in art. 17 of Regulation n. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Authority, are met.

ALL OF THE ABOVE STATED, THE AUTHORITY

declares the unlawfulness of the processing of personal data carried out by the University Hospital Company Policlinico "G. Martino" - Tax Code: 03051890832, located in Messina, Via Consolare Valeria – postal code 98124, for the violation of arts. 5, par. 1, lett. f), 9, 12 in relation to arts. 15 and 32 of the Regulation as stated in the reasoning;

ORDERS

pursuant to arts. 58, par. 2, lett. i) and 83 of the Regulation, as well as art. 166 of the Code, the aforementioned Hospital Company to pay the sum of €8,000.00 (eight thousand) as an administrative pecuniary sanction for the violations indicated in this provision, according to the methods highlighted in the annex, within 30 days from the notification in reasoning; it is represented that the offender, pursuant to art. 166, paragraph 8, of the Code, has the option to settle the dispute by payment, within the term of 30 days, of an amount equal to half of the imposed sanction.

ENJOINS

the aforementioned healthcare company, in case of failure to settle the dispute pursuant to art. 166, paragraph 8, of the Code, to pay the sum of €8,000.00 (eight thousand) according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of subsequent executive acts in accordance with art. 27 of law n. 689/1981.

DISPOSES

pursuant to art. 166, paragraph 7, of the Code, the full publication of this provision on the website of the Authority and considers that the conditions referred to in art. 17 of Regulation n. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Authority, are met.

Pursuant to art. 78 of the Regulation, arts. 152 of the Code, and 10 of Legislative Decree n. 150/2011, against this provision it is possible to appeal to the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, December 7, 2023

THE PRESIDENT

Stanzione

THE REPORTER

Cerrina Feroni

THE SECRETARY GENERAL

Mattei